

COBIT

Capítulo 1

COBIT

Podemos definir a COBIT como un marco de referencia para el gobierno y la gestión de la información y la tecnología, dirigido a TODA LA EMPRESA. Está dirigido a la I&T (Infraestructura y Tecnología) de toda la empresa que utiliza para alcanzar sus objetivos, independientemente de dónde ocurra esto dentro de la empresa; por esto no nos limitamos al departamento de TI, aunque está incluido.

Se realiza la distinción entre **gobierno** y **gestión**, son dos disciplinas que abarcan distintos tipos de actividades, y requieren distintas estructuras organizativas y sirven a diferentes propósitos.

El gobierno son:

- Las necesidades, condiciones y opciones de las partes interesadas que determinan los objetivos acordados.
- La dirección se establece a través de la priorización y la toma de decisiones.
- El rendimiento y cumplimiento se monitorean en relación de lo anterior.

En la mayoría de empresas el "gobierno" es responsabilidad del consejo de dirección, bajo el liderazgo del presidente (o de quien mueva la batuta).

La **gestión** planifica, construye, ejecuta y monitorea actividades alineadas con la dirección establecida por el org. del gob. para alcanzar los obj de la emp. La gestión suele ser responsabilidad exclusiva del CEO.

Cobit define los componentes para crear y sostener un sistema de gobierno; los procesos, estructuras org, políticas y procedimientos, flujos de info, cultura, comportamientos, habilidades e infra. Además de considerar los factores que la empresa debe tener para poseer un gobierno adecuado.

COBIT NO ES

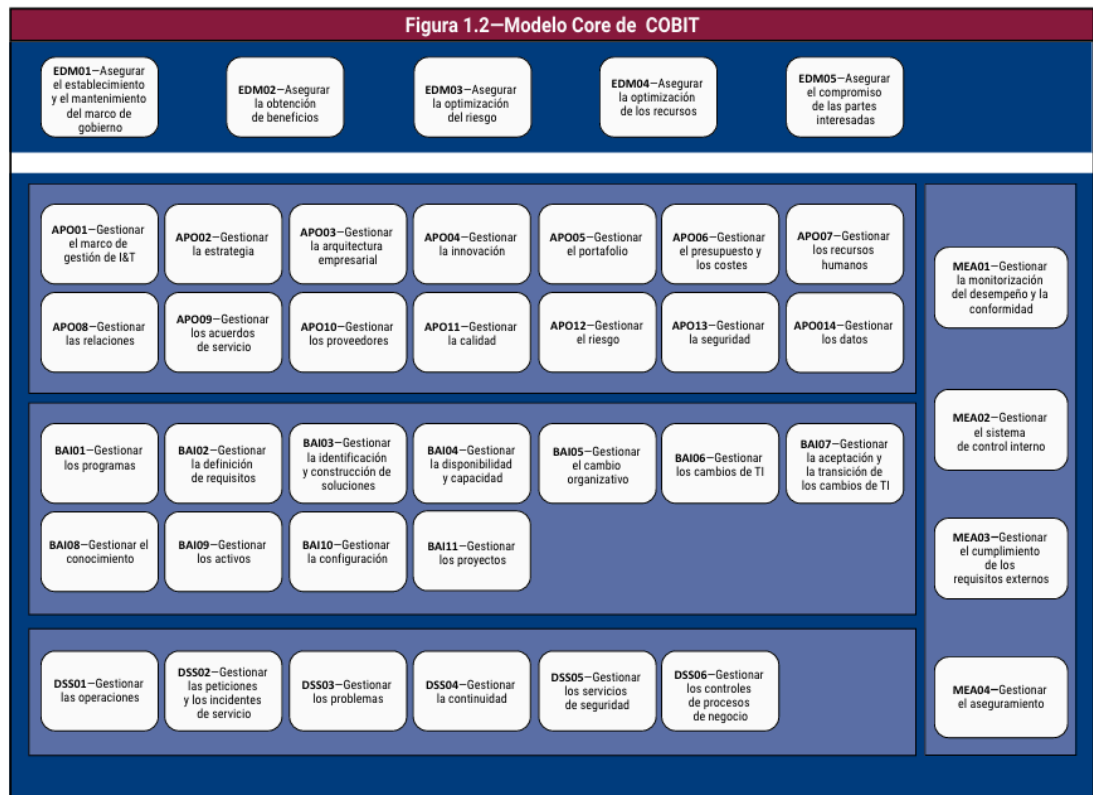
- Una descripción completa del entorno de TI de la empresa
 - Es global, va más allá del propio TI
- Marco de referencia para organizar procesos.
 - Para eso te vas con la ISO 9001 que es la que te da esta parte.
- Marco de referencia técnico para gestionar tecnología
 - Contrata a alguien que te ayude con esto.
- No toma ninguna decisión relacionada con TI, No decide cual es la mejor estrategia de TI, cual es la mejor arq o cosas a nivel específico.

COBIT define todos los componentes, que describen qué decisiones deberían tomarse, cómo deberían tomarse y quién debería tomarlas.

Terminología y conceptos clave del marco de referencia de COBIT

La info y la tec. deben contribuir a los objetivos de la empresa, alcanzando una serie de objetivos de gob. y gestión.

- Un objetivo de g&g (gobierno y gestión) **siempre debe estar relacionado con un proceso.**
- Un objetivo de gobierno está relacionado con un proceso de gobierno, mientras que un objetivo de gestión está relacionado con un proceso de gestión.
- Los objetivos de gestión los agrupamos en cuatro dominios:
 - **Alinear, Planificar y Organizar (APO):** Aborda la org general, estrategia y actividades de apoyo para la info y la tec (I&T)
 - **Construir, Adquirir e Implementar (BAI):** la definición, adquisición e implementación de soluciones y su integración en los procesos de negocios.
 - **Entregar, Dar Servicio y Soporte (DSS):** La entrega operativa y el soporte de servicios de I&T, incluida la seguridad.
 - **Monitorizar, Evaluar y Valorar (MEA)** La monitorización del rendimiento y la conformidad de I&T, con los obj. de rendimientos internos, los obj. del control internos y los req. externos.
 - Leer por encima el siguiente cuadro:



Componentes de un sist de gobierno

Cada empresa tendrá su propio sistema de gobierno, por esto debe establecer, personalizar y sostener el suyo creado a partir de sus componetes.

- Son factores que, de forma individual y colectiva, contribuyen al buen funcionamiento del sistema de gobierno de la empresa en cuanto a I&T.
- Los componentes interactúan entre sí, por lo tanto es holístico de I&T.
- Son procesos, estructuras organizativas, políticas y procedimientos, elementos de información, cultura y comportamiento, habilidades y competencias, servicios, infraestructura y aplicaciones. (Lo que significa c/u es re mil chamuyable)

Figura 1.3—Componentes COBIT de un sistema de gobierno



Estos componentes son una base, pero los podemos personalizar según lo que necesitemos; dándole más bola a ciertas cosas específicas.

Áreas prioritarias

Describe determinado tema de gobierno, dominio o problema que puede ser abordado por una colección de obj de g&g y sus componentes. Las áreas prioritarias por ejemplo podrían ser ciberseguridad, transformación digital, cloud, privacidad y DevOps.

Capítulo 2

El pdf tiene 40 objetivos de g&g definidos en el modelo core de COBIT, de ahí en más el resto no importa.

Público destinatario

Enfocado para profesionales del mundo empresaria, personas del negocio, auditores, seguridad, gestión de riesgos, TI y cualquier profesional que entienda los objetivos de g&g.

Capítulo 3 (Estructura de objetivos de g&g de COBIT)

Introducción

Mencionamos anteriormente que los componentes de g&g son:

- Proceso
- Estructura organizativa
- Flujos y elementos de información
- Personas, habilidades y competencias
- Políticas y procedimientos
- Cultura, ética y comportamiento
- Servicios, infraestructura y aplicaciones

Objetivos de g&g

Los 40 objetivos de g&g están organizados en cinco dominios

- Dominio de Gobierno
 - Evaluar, Dirigir y Monitorizar (EDM)
- Dominio de Gestión
 - **Alinear, Planificar y Organizar (APO)**
 - **Construir, Adquirir e Implementar (BAI)**
 - **Entregar, Dar Servicio y Soporte (DSS)**
 - **Monitorizar, Evaluar y Valorar (MEA)**

Cascada de metas

Cada objetivo de g&g está relacionado con las metas empresariales más importantes. Se puede establecer una correlación biunívoca entre ellas, ej:

Figura 3.2—Presentación de metas empresariales y de alineamiento	
El objetivo de gobierno/gestión respalda el logro de una serie de metas empresariales y de alineamiento primarias:	
Metas empresariales	Metas de alineamiento
• <EG REF> <DESCRIPCIÓN DE METAS>	• <AG REF> <DESCRIPCIÓN DE METAS>

EG01: Portafolio de productos y servicios competitivos

AG01: Cumplimiento y soporte de I&T para el cumplimiento empresarial con las leyes y regulaciones externas

(Hay varios más, pero ya se entiende con este)

Como sabemos de calidad, nada que no se mide se puede mejorar, así que también se pueden agregar métricas al modelo anteriormente propuesto. (chamuyar por ese lado)

Figura 3.3—Presentación de metas aplicables y métricas modelo	
El objetivo de gobierno/gestión respalda el logro de una serie de metas empresariales y de alineamiento primordiales:	
Metas empresariales	➔ Metas de alineamiento
<EG REF> <DESCRIPCIÓN DE METAS>	<AG REF> <DESCRIPCIÓN DE METAS>
Métricas modelo para metas empresariales	Métricas modelo para metas de alineamiento
<EG REF> • <MÉTRICA>	<AG REF> • <MÉTRICA>
<EG REF> • <MÉTRICA>	<AG REF> • <MÉTRICA>

Componente Proceso

Cada objetivo de g&g tiene varias prácticas de proceso, cada proceso incluye una o más actividades; cada práctica del proceso viene acompañada con un número limitado de métricas del modelo para medir el logro del mismo en la práctica, y su contribución al alcance del objetivo.

(Las img. son meramente ilustrativas, no creo que nos pidan algo así)

Figura 3.4—Presentación del componente de procesos		
A. Componente: Proceso		
Práctica de gobierno/gestión	Métricas modelo	
<REF> <NOMBRE> <DESCRIPCIÓN>	<MÉTRICA>	
Actividades		Nivel de capacidad
1. <TEXTO>		<NR>
2. <TEXTO>		<NR>
n. <TEXTO>		<NR>
Documentación relacionada (Estándares, Marcos, Requisitos de cumplimiento)	Referencia específica	
<NOMBRE DEL ESTÁNDAR>	<TEXTO>	
<NOMBRE DEL ESTÁNDAR>	<TEXTO>	

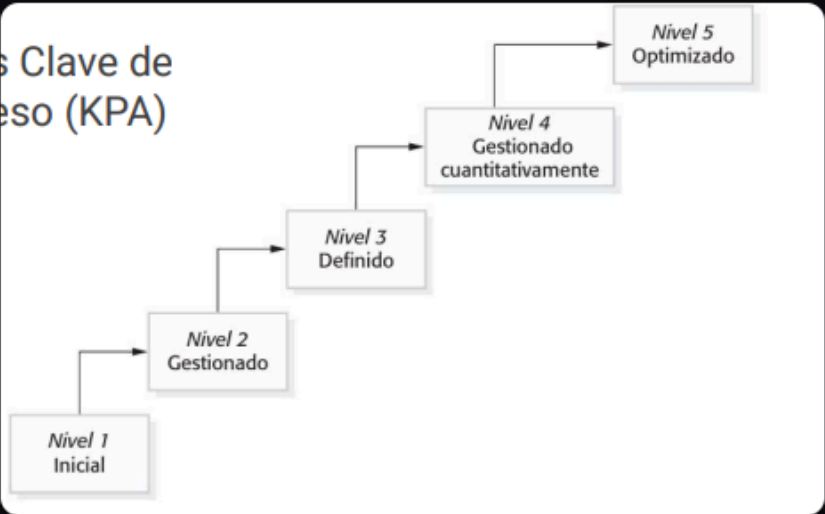
Los procesos pueden tener distintos niveles de madurez de los mismos, **(ES LITERAMENTE LA MISMA CAGADA QUE EN ING DE SOFTWARE)**, van desde el "0" hasta el 5, dependiendo de cuan maduro sea un proceso. A terminos prácticos el 0 es malardo y el 5 es que es piolardo y certificó iso ponele algo así.

Modelos de Madurez

CMM - CMMI

Propuesto por el SEI (Software Engineering Institute)
CMM - Software Capability Maturity Model
Modelo de madurez de Capacidades de Software
Evoluciona específicamente en el CMMI
Que es el Modelo de Madurez de Capacidades de Software Integrado

Destaca las áreas clave de proceso (KPA) y va por niveles según dependa.



ISO/IEC

Del otro lado tenemos la mejora de procesos por medio de la norma ISO/IEC (International Organization for Standardization) (Comisión Electrotécnica Internacional)

Específicamente tenemos la norma 15504 - SPICE (Software Process Improvement Capability Determination); Determinación de la Capacidad de la Mejora del Proceso de Software.

Tiene 6 niveles, que son:

- 1) Incompleto
- 2) Realizado
- 3) Gestionado
- 4) Establecido
- 5) Predecible
- 6) En optimización

Vicent había dicho que no le demos bola a este pero qsy

Nivel	Descripción resumida
0 – Incompleto	Sin capacidad básica ni estrategia clara; el proceso puede no estar definido.

Nivel	Descripción resumida
1 – Inicial	Actividades intuitivas o desorganizadas; el proceso logra su propósito de forma irregular.
2 – Gestionado	Actividades básicas completas y repetibles; el proceso se realiza consistentemente.
3 – Definido	Procesos bien estructurados y estandarizados en toda la organización.
4 – Cuantitativamente gestionado	El rendimiento se mide con datos y métricas para controlar el proceso.
5 – Optimizado	Mejora continua basada en mediciones y análisis; el proceso se perfecciona constantemente.

Componente: Estructuras organizativas

Sugiere niveles de responsabilidad y rendición de cuentas para las prácticas de los procesos.

Se definen los siguientes roles y estructuras dentro de cobit:

- Consejo de Admin.
- CEO
- CFO
- COO
- CRO pasa el revolver
- CIO
- CTO
- cdo
- muchos c y fue chamuyen que se yo

Cada uno de estos roles, está en algún apéndice del cobit, y así mismo tiene la información detallada de cuáles deberían ser sus alcances y sus funcionalidades, que debería hacer y hasta dónde se debería limitar.

Así mismo cobit, nos indica lo siguiente los "**Responsables**" (R) son aquellos que tienen la función de completar la actividad y generar el resultado; responden al ¿Quién realiza la tarea? Quien dirige la tarea?

Existen los roles a quien se rinde cuentas (A) que serían quienes están interesados que su rol lo cumpla correctamente.

Podemos agregar distintos roles según sea necesario por ejemplo roles de **Consultado** (**C**) > ¿Quién está proporcionando la información

Los roles de **Informado (I)** ¿Quién está recibiendo la info?
Esto depende de cada empresa y según defina su contexto.

Componente: Flujos y elementos de información

Proporciona una guía sobre los flujos y elementos de información vinculados con las prácticas de los procesos; Cada práctica incluye entradas y salidas, con origen y destino. En síntesis es una documentación técnica de como fluye la información en la org.
(Irrelevante)

Componente: Personas, habilidades y competencias.

Identifica los recursos humanos y las habilidades requeridas para alcanzar los objetivos de g&g.
Vendría a ser un relevamiento básicamente de que se necesita para ser un competente en el trabajo.

Componente: Políticas y procedimientos

Guía detallada para lograr los objetivos, políticas y procedimientos relevantes con la descripción del propósito, si es posible referencia al iso 9001

Componente: Cultura, ética y comportamiento

Una guía detallada sobre los elementos deseados dentro de la org que respaldan el objetivo de g&g. Básicamente portate bien y que nadie sea mala persona

Componente: Servicios infraestructura y aplicaciones

Proporciona una guía detallada sobre las cosas de terceros que podemos utilizar para respaldar la obtención de los objetivos de g&g. La guía es genérica y no nombra proveedores,

ISO 27001

Introducción

Antecedentes y contexto

Debe usarse como referencia para determinar e implementar controles para el tratamiento de riesgos de seguridad de la información en un **SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN** (SGSI) basado en el estándar. Puede ser utilizado como documento de organización para determinar e implementar controles de seguridad de la información.

Está dirigido para cualquier organización, de cualquier tipo y tamaño; que crean, recopilan,

procesan, almacenan, transmiten, y eliminan información en cualquiera de sus formas.

La seguridad de la información solo se logra, mediante un conjunto adecuado de controles, incluidas las políticas, reglas, procesos, procedimientos, estructuras organizativas y funciones de soft y hard. Para cumplir objetivos comerciales y de seg específicos.

Un SGSI adopta una visión holística y coordinada de los riesgos de la seg de la info de la org para implementar un conjunto integral de controles de seg de la info dentro del marco de un sgisi coherente.

Un SGSI adecuado y eficaz proporcionar garantías a la alta dirección y al resto de partes interesadas que su información y otros activos se mantienen razonablemente seguros y protegidos contra amenazas y daños, lo que permite alcanzar los objetivos comerciales establecidos.

Req. de seg de info

Existen tres fuentes de req. de seg. de la info

1. La evaluación de los riesgos de la org, teniendo en cuenta la estrategia y los objetivos comerciales. Esto detemrina los controles necesarios para asegurar el riesgo residual para la org.
2. Los req. legales, estatutarios, reglamentarios y contractuales que debe cumplir una org y sus partes interesadas.
3. El conjunto de principios, objetivos y requisitos comerciales para todos los pasos del ciclo de vida de la info.

Controles

Un control es la medida que modifica o mantiene el riesgo; entre los controles de la ISO, están aquellos que modifican el riesgo, mientras que otros mantienen el riesgo. Una política de sge. de la info, solo puede mantener el riesgo; mientras que el cumplimiento de la política de seg de la info. puede modificar el riesgo.

Determinación de los controles

La determinación de los controles depende de las decisiones de la org, luego de la evaluación de riesgos, con un alcance claramente definidos. Las deciisones relacionadas con los riesgos identificados, deben basarse en los criterios de aceptación del riesgo; debe tener en cuenta las leyes y reglamentos nacionales e internacionales pertinentes. Y también de como los controles interactuan entre sí para brindad una buena defensa.

La org puede diseñar controles segun vea conveniente, pero al especificar dichos controles; la org. debe hacerse cargo e invertir para implementar y operar dicho control.

Debe existir un equilibrio entre los recursos desplegados para implementar los controles y el posible impacto comercial resultante de no tener dichos controles; con esto se debe guiar a

la gestión adecuada, las prioridades para gestionar los riesgos.

Los controles de la ISO se pueden considerar como principios rectores para la gestión de la seguridad de la información.

Elaboración de directrices específicas para la org.

Es el punto de partida para el desarrollo de directrices específicas de la org. No todo se puede aplicar en una org, y también puede ser necesario buscar nuevos adicionales para abordar necesidades específicas, es solo una GUÍA.

Recordar: las iso q terminen en 1 se certifican, las q terminan en 2 son una guía simplemente (la que estamos estudiando es la q termina en 2)

Consideraciones sobre el ciclo de vida

La info tiene un ciclo de vida, desde que nace hasta que se muere (se elimina). El valor y el riesgo puede variar; por lo tanto es importante la seg de dicha info, en casi todas sus etapas.

Siempre intentar mejorar como tratamos con la información recopilada para ir mejorando los controles sobre el ciclo de vida.

Normas internacionales relacionadas.

Leete la 27000 que es una introducción general al SGSI y existen específicas como por ejemplo

la 27017 para cloud la 27701 para privacidad la 27019 para energia la 27011 para telecomunicaciones y la 27799 para salud.

Alcance

Proporciona un conjunto de controles genéricos de seguridad de la info, incluida la guía de implementación. Esta pensado para organizaciones:

1. Dentro del contexto de un SGSI basado en 27001
2. Implementar controles de seguridad basado en las mejores prácticas reconocidas internacionalmente
3. Desarrollar directrices de gestión de la seguridad de la info específicas de al org.

Referencias Normativas

no hay uwu

Términos, definiciones y términos abreviados

- **Control de acceso:** Medios para asegurar el acceso físico y lógico a los activos, este autorizado y restringido dependiendo de los req de la org.
- **Activo:** Cualquier cosa que tenga valor para la org
 - Primarios: información, procesos actividades
 - De apoyo: software, red, personal, etc.
- **Ataque:** Intento no autorizado exitoso o fallido para destruir, alterar o deshabilitar el acceso a un activo
- **Autenticación:** Garantía de que una característica de una entidad
- **Autenticidad:** Propiedad de una entidad
- **Cadena de custodia:** Posesión demostrable, mov, manejo y ubicación de material de un punto en un tiempo a otro.
- **Info concidencial:** Info no destinada a ser divulgada.
- **Control:** Medida que mantiene y/o modifica el riesgo
- **Ruptura:** Incidente, ya sea anticipado o no, que causa una desviación negativa en la entrega esperada de productos y servicios
- **Entidad:** Elemento relevante para el propósito de la operación
- **Violación de la seguridad de la información:** Ocurrencia que indica una violación en la seg. de la info
- **Incidente de la seg de la información** Eventos de la seguridad de la información que pueden dañar los activos de la org.
- **Gestión de incidentes de seguridad de información:** Enfoque consistente para el manejo de los incidentes de la seg de la información
- **Parte interesada** : Persona u organización que puede afectar, ser afectada o percibirse a sí misma como afectada por una decisión.
- **Política** intenciones y dirección de una organización, expresada por la alta dirección
- **Procedimiento** forma específica de llevar a cabo una actividad o un proceso
- **Proceso** conjunto de actividades interrelacionadas ..
- **Registro** info creada, recibida y mantenida como evidencia y como activo para una org o persona cumpliendo con las obligaciones legales.
- **Fiabilidad** propiedad de comportamiento y resultados previstos
- **Amenaza** causa potencial de un incidente no deseado, que puede resultar en el daño de un sist o org.
- **Vulnerabilidad** debilidad de un activo

Los términos abreviados serán obviados pero ejemplo de algunos, UPC, CAD, DNS, GPS, SOY, TIC, IDE, IP, IPS, SGSI, MAC, RBAC, SDN, SQL, UPS, VPN

Estructuras

Tiene la siguiente estructura:

1. Controles organizacionales
2. Controles de personas
3. Controles físicos
4. Controles tecnológicos

Existen 2 anexos,

La org. puede crear atributos para crear diferentes vistas que son diferentes categorizaciones de controles vistos desde una perspectiva diferente a los temas; los atributos sirven para filtrar, ordenar y presentar las vistas. El anexo a abarca más este tema.

Cada control se asoció a 5 atributos, siendo:

1. Tipo de control
 1. Se utiliza para ver la perspectiva de cuándo y cómo el control modifica el riesgo con respecto a la ocurrencia de un incidente de seg de la información, siendo **preventivo, detectivo, y correctivo.**
2. Propiedades de seg de la info
 1. Se utiliza para ver que característica de la info se preservará, siendo: **Confidencialidad, Integridad y Disponibilidad**
3. Conceptos de ciberseguridad
 1. Para ver los controles desde la perspectiva a los conceptos de ciberseguridad definidos en el marco de otra ISO, los valores pueden ser: **Identificar, Proteger, Detectar, Responder y Recuperar**
4. Capacidades operativas
 1. Desde la perspectiva profesional de las capacidades de seg de la info, siendo muchas así que da igual, gobernanza, gestión de activos, protección de info, seg de rhh, seg física etc etc
5. Dominios de Seguridad
 1. Perspectiva de los cuatro dominios de seg de la info, siendo **Gobierno y ecosistema**, son muchos bla bla

Son lo más genérico posible para que lo use cualquier org.

La idea es que el diseño sea el siguiente:

Título del control

Tabla de atributos

Control

Propósito

Guia
Info adicional